

Network Security

Lecture 3b

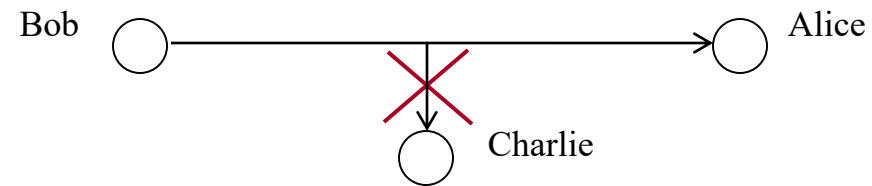
Authentication

Today!

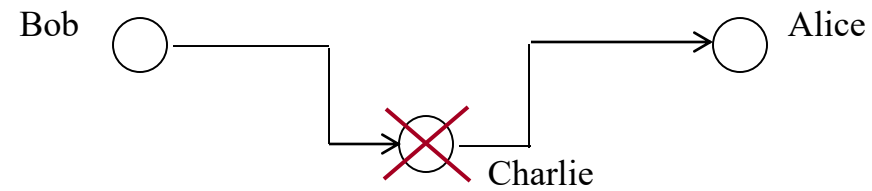
- Authentication
- Authorization
- Accountability (logs)
- Applied Cryptography



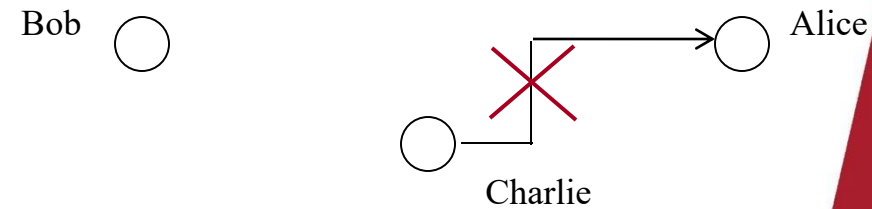
1. Confidentiality



2. Message integrity



3. Message authentication



Possible additional concepts:

Authenticity

- Verifying that users are who they say they are and that each input arriving at the system came from a trusted source

Accountability

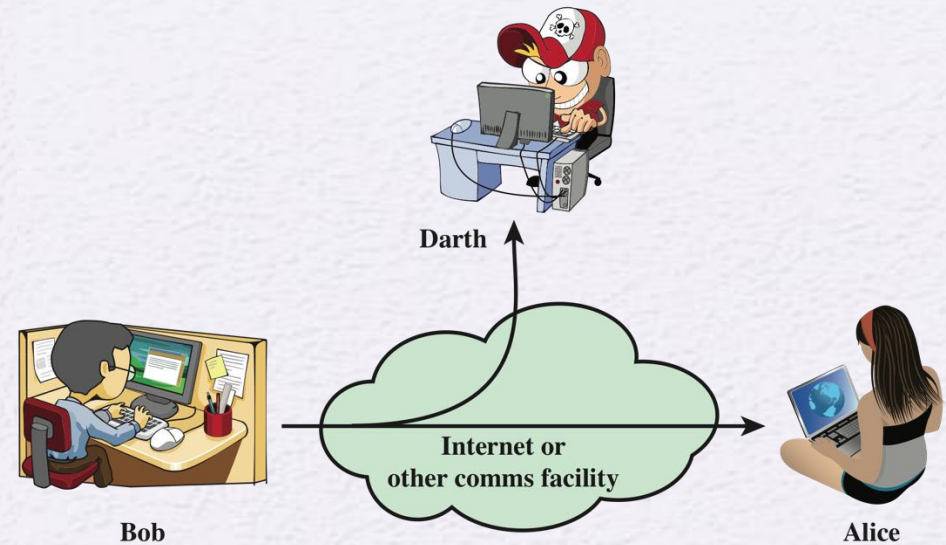
- The security goal that generates the requirement for actions of an entity to be traced uniquely to that entity



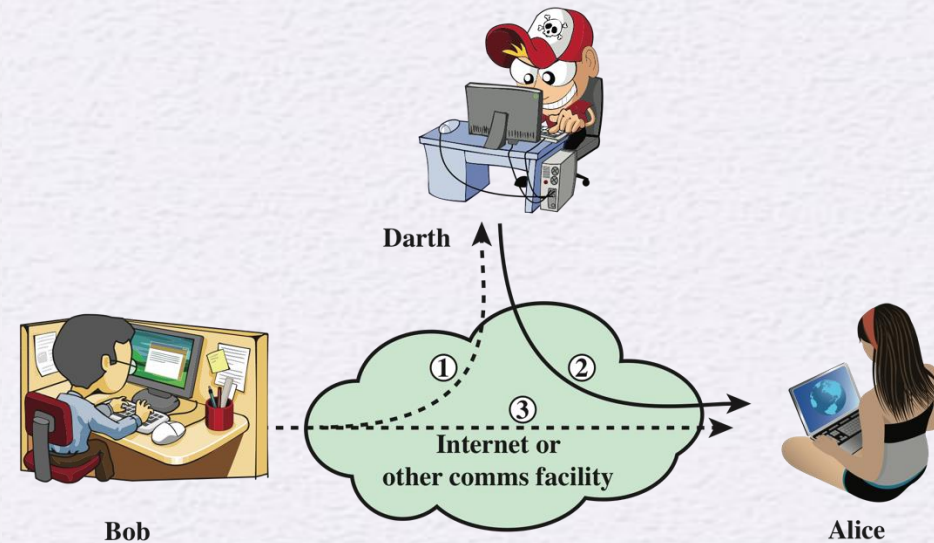
University of
BRISTOL

Security Attacks

- A means of classifying security attacks, used both in X.800 and RFC 4949, is in terms of *passive attacks* and *active attacks*
- A *passive attack* attempts to learn or make use of information from the system but does not affect system resources
- An *active attack* attempts to alter system resources or affect their operation



(a) Passive attacks



(b) Active attacks

Passive Attacks

- Are in the nature of eavesdropping on, or monitoring of, transmissions
- Goal of the opponent is to obtain information that is being transmitted



- Two types of passive attacks are:
 - The release of message contents
 - Traffic analysis

Active Attacks

- Involve some modification of the data stream or the creation of a false stream
- Difficult to prevent because of the wide variety of potential physical, software, and network vulnerabilities
- Goal is to detect attacks and to recover from any disruption or delays caused by them



Masquerade

- Takes place when one entity pretends to be a different entity
- Usually includes one of the other forms of active attack

Replay

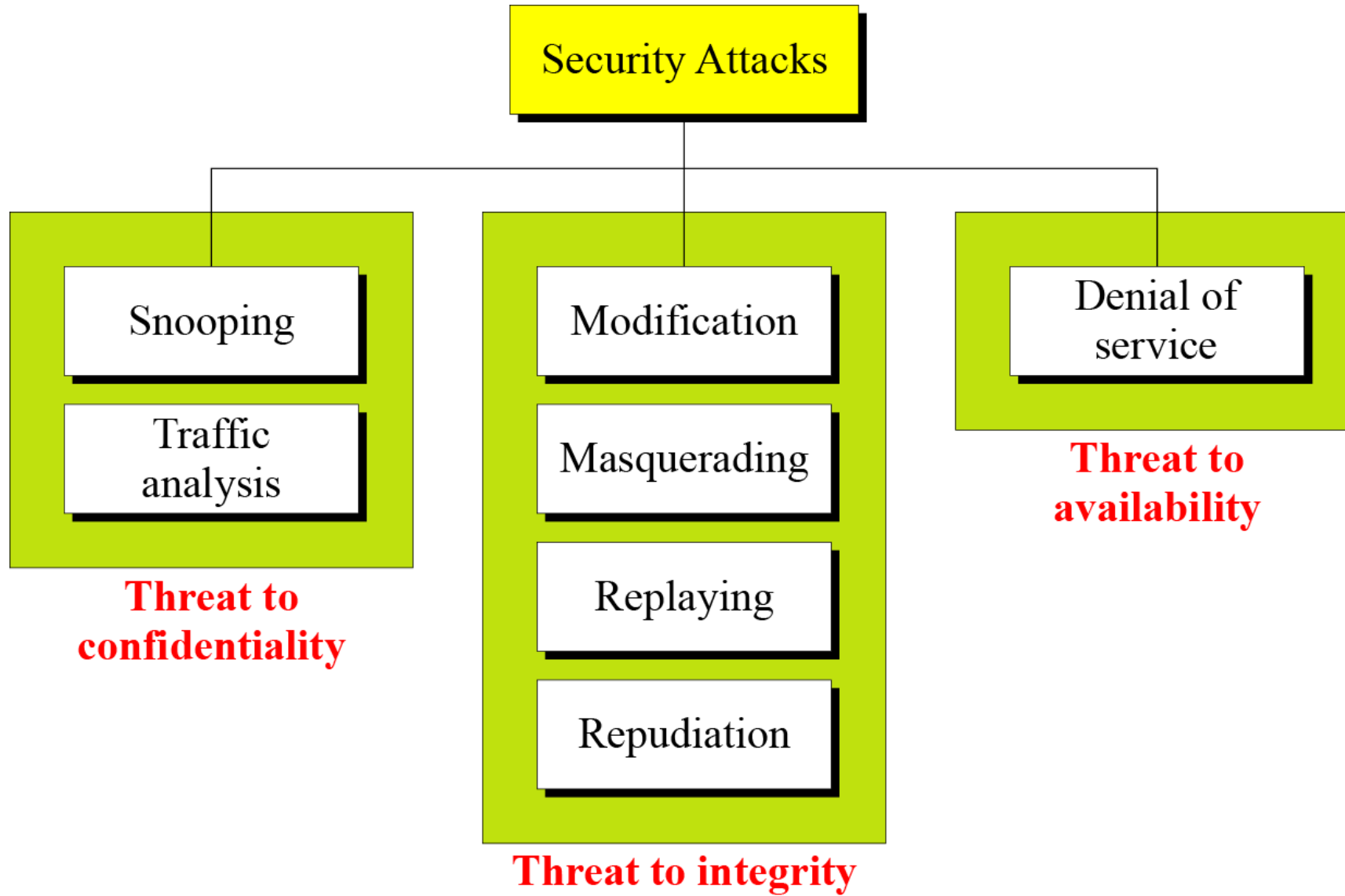
- Involves the passive capture of a data unit and its subsequent retransmission to produce an unauthorized effect

Modification of messages

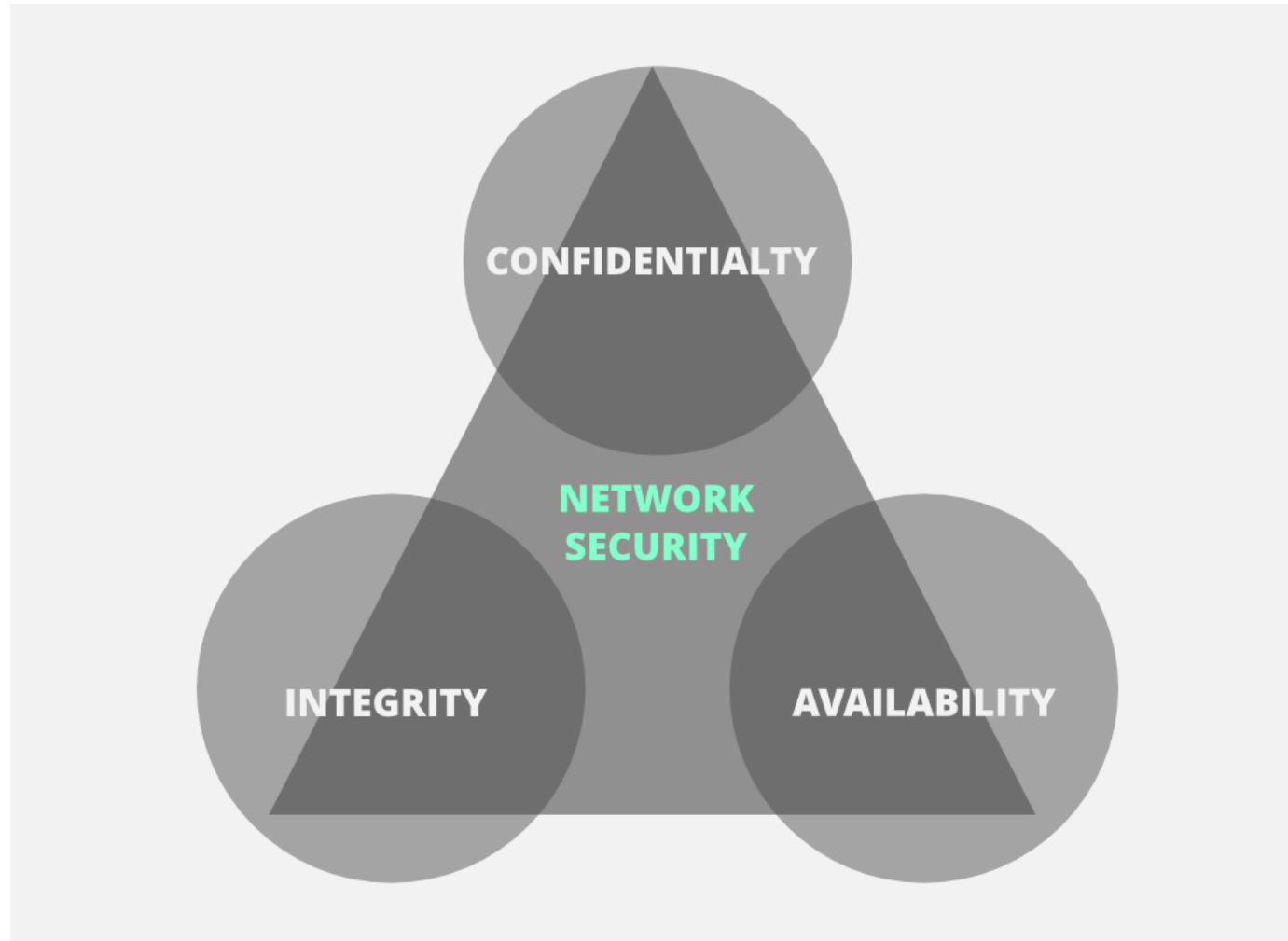
- Some portion of a legitimate message is altered, or messages are delayed or reordered to produce an unauthorized effect

Denial of service

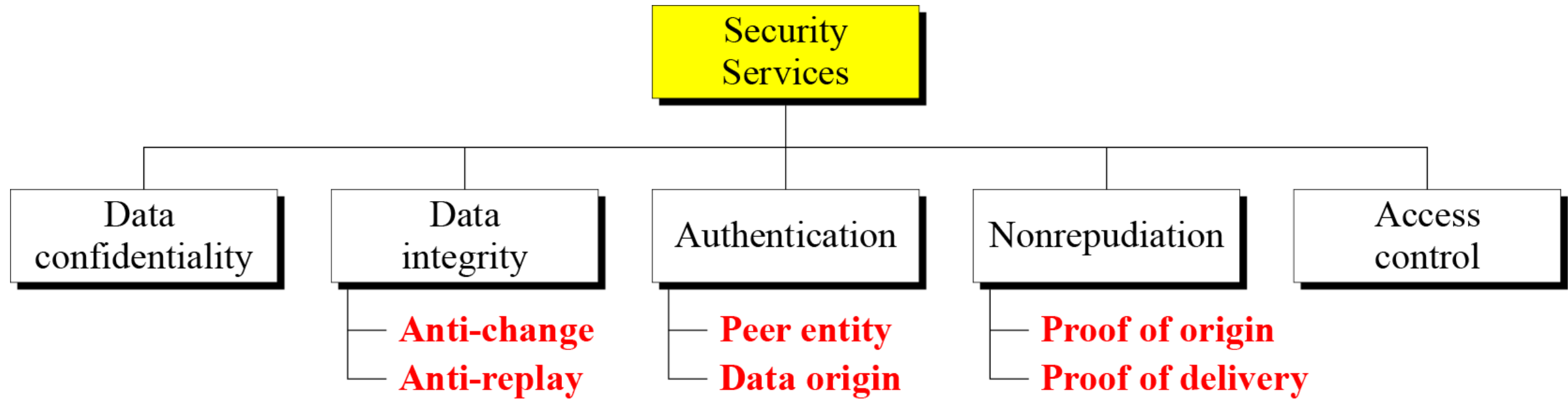
- Prevents or inhibits the normal use or management of communications facilities



CIA Triad



Security services



Access Control

- The ability to limit and control the access to host systems and applications via communications links
- To achieve this, each entity trying to gain access must first be indentified, or authenticated, so that access rights can be tailored to the individual



Authentication:

Or who are you?



Authorization:

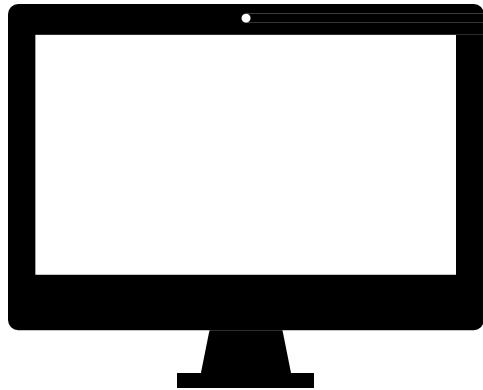
Or what can you do?

Accountability:

Or who did what?

Authentication

Who are you?



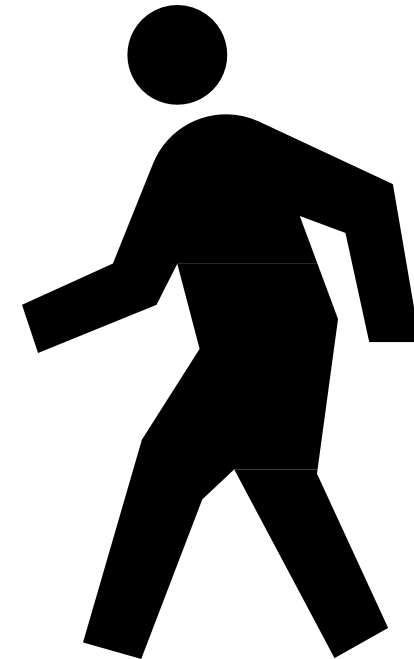
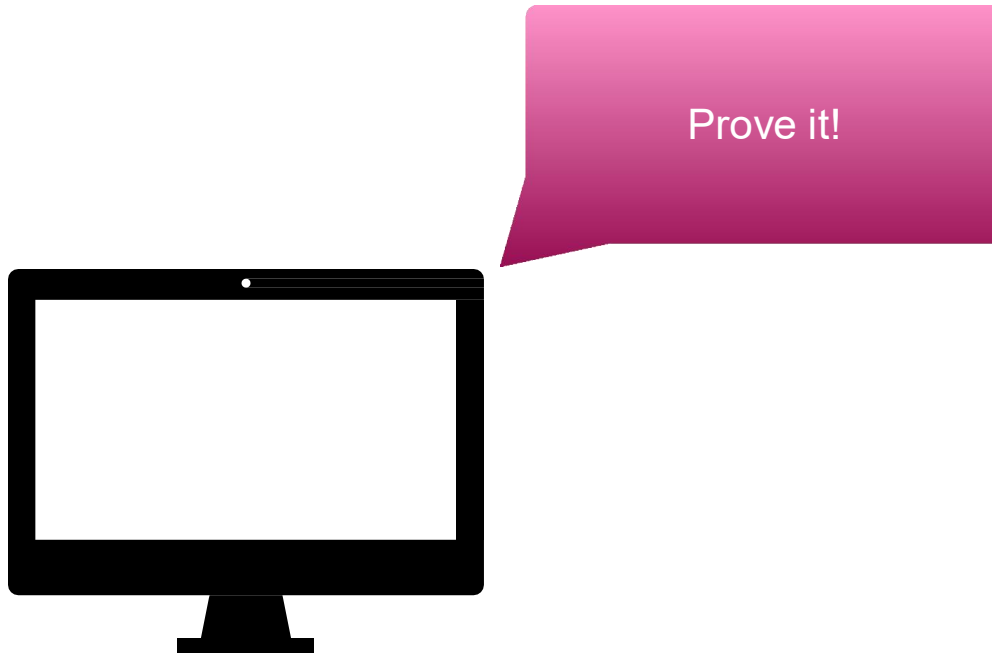
I am John Smith and I'd like to use this computer...



bristol.ac.uk

Authentication

Who are you?



bristol.ac.uk

Authentication

3 Basic Mechanisms

Something you know

- **Passwords**

Something you have

- **Keys**

Something you are

- **Biometrics and behaviours**

Authentication

3 Basic Mechanisms

Something you know

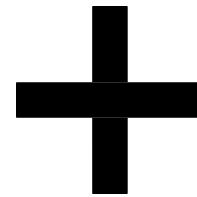
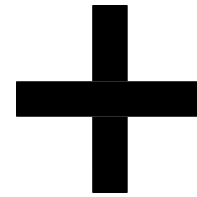
- Passwords

Something you have

- Keys

Something you are

- Biometrics and behaviours



Multi-factor
authentication

Authentication

Passwords and gotchas

Storing passwords isn't hard
...but everyone gets it wrong.

Just go look up what current
best practice is.

(Randomize the salt, 1024
rounds of bcrypt...)

bristol.ac.uk

COMPUTER SECURITY



NIST Special Publication 800-63-3

Digital Identity Guidelines

Paul A. Grassi
Michael E. Garcia
*Applied Cybersecurity Division
Information Technology Laboratory*

James L. Fenton
*Altmode Networks
Los Altos, Calif.*

This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-63-3>

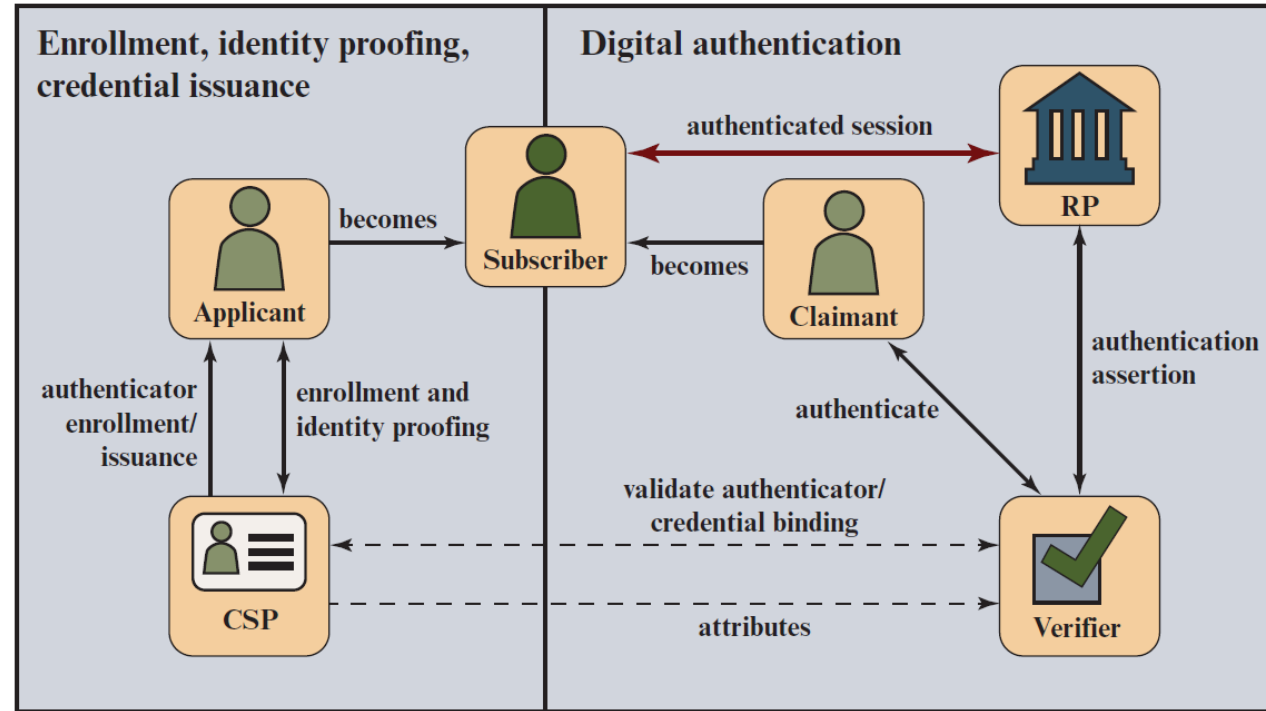
June 2017
Includes [updates](#) as of 03-02-2020



U.S. Department of Commerce
Wilbur L. Ross, Jr., Secretary

National Institute of Standards and Technology
Kent Rochford, Acting NIST Director and Under Secretary of Commerce for Standards and Technology

The NIST 800-63 Digital Identity Model



CSP = credential service provider
RP = relying party

Authentication

Keys

Something you have!

Typically a digital signature of some kind...

- PGP is hard (-ish)

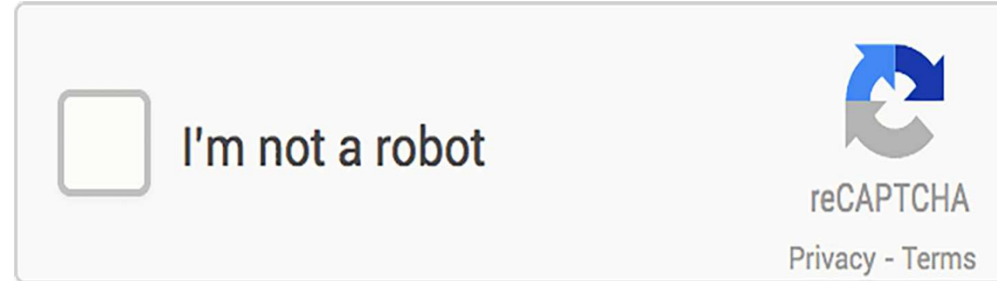
What happens if you lose it?



Authentication

Biometrics

Something you are!



Track something about a person...

- Gait... mouse movements... usage patterns
- Build a machine learning model about it
- How do you repudiate your fingerprints?
- How do you handle accessibility?

Authentication

Federated Identity Management

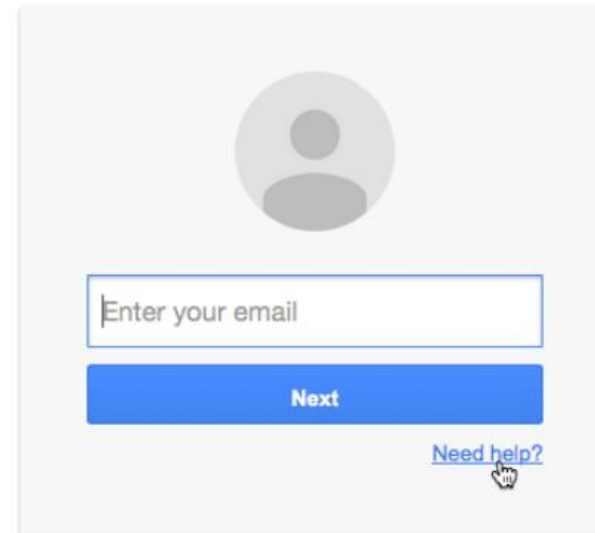
Delegate to someone else for your identity management!

- Great for organisations
 - ...centralised employee management!
- Great for amateur developers
 - ...less to get wrong/GDPR compliance!
- Bad for privacy
 - ...if you lose access to your Google account you lose access to EVERY connected service.

Kerberos, LDAP, OAuth2...

One account. All of Google.

Sign in with your Google Account

A screenshot of the Google sign-in interface. At the top is a grey circular profile picture placeholder. Below it is a text input field with the placeholder text "Enter your email". Under the input field is a blue button with the word "Next" in white. At the bottom right of the sign-in box is a blue link that says "Need help?".

Enter your email

Next

[Need help?](#)

Means of User Authentication (1 of 3)

There are three general means, or *authentication factors*:

Knowledge factor (something the individual knows):

- Requires the user to demonstrate knowledge of secret information.
- Routinely used in single-layer authentication processes, knowledge factors can come in the form of passwords, passphrases, personal identification numbers (PINs), or answers to secret questions



Means of User Authentication (2 of 3)

- **Possession factor** (something the individual possesses):
- Physical entity possessed by the authorized user to connect to the client computer or portal. This type of authenticator used to be referred to as a token, but that term is now deprecated.
 - Connected hardware tokens are items that connect to a computer logically (e.g., via wireless) or physically in order to authenticate identity. Items such as smart cards, wireless tags, and USB tokens are common connected tokens used to serve as a possession factor
 - Disconnected hardware tokens are items that do not directly connect to the client computer, instead requiring input from the individual attempting to sign in.

Means of User Authentication (3 of 3)

- **Inherence factor** (something the individual is or does):
 - Refers to characteristics, called **biometrics**, that are **unique** or **almost unique** to the individual.
 - Static biometrics:
 - fingerprint, retina, and face;
 - Dynamic biometrics:
 - voice, handwriting, and typing rhythm...



User-Authentication

- The process of determining whether some user or some application or process acting on behalf of a user is, in fact, who or what it declares itself to be
- Authentication technology provides access control for systems by checking to see if a user's credentials match the credentials in a database of authorized users or in a data authentication server
- Authentication enables organizations to keep their networks secure by permitting only authenticated users (or processes) to access its protected resources
- User authentication is distinct from message authentication
 - Message authentication is a procedure that allows communicating parties to verify that the contents of a received message have not been altered and that the source is authentic

Authentication Principles (1 of 2)

- **Digital identity:**

- The unique representation of a subject engaged in an online transaction
- The representation consists of an attribute or set of attributes that uniquely describe a subject within a given context of a digital service, but does not necessarily uniquely identify the subject in all contexts

- **Identity proofing:**

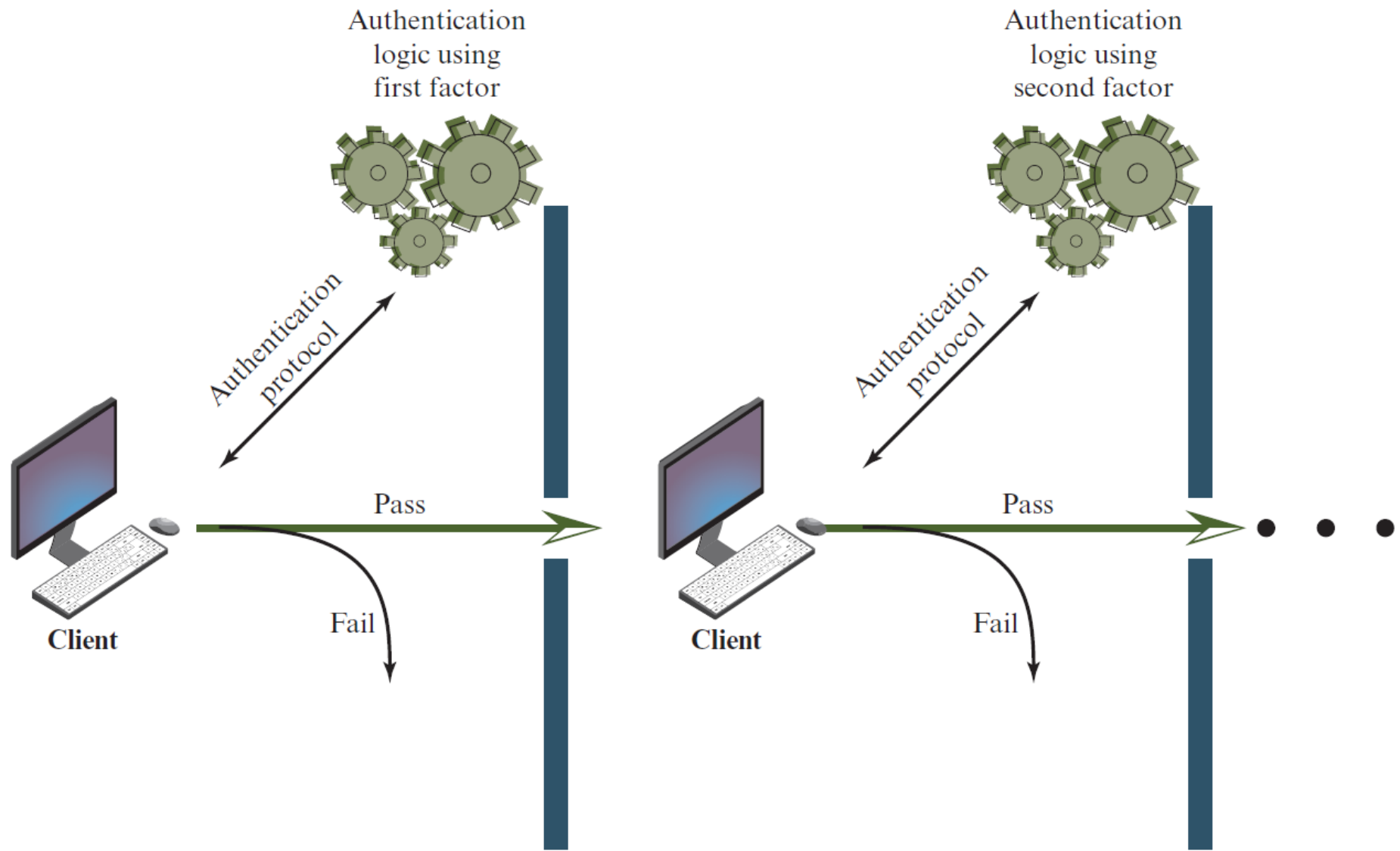
- Establishes that a subject is who they claim to be to a stated level of certitude
- This process involves collecting, validating, and verifying information about a person

Authentication Principles (2 of 2)

- **Digital authentication:**
 - The process of determining the validity of one or more authenticators used to claim a digital identity
 - Authentication establishes that a subject attempting to access a digital service is in control of the technologies used to authenticate
 - Successful authentication provides reasonable risk-based assurances that the subject accessing the service today is the same as the subject that previously accessed the service

Authentication factors

Factor	Examples	Properties
Knowledge	User ID	Can be shared
	Password	Many passwords easy to guess
	PIN	Can be forgotten
Possession	Smart Card	Can be shared
	Electronic Badge	Can be duplicated (cloned)
	Electronic Key	Can be lost or stolen
Inherence	Fingerprint	Not possible to share
	Face	False positives and false Negatives possible
	Iris	
	Voice print	Forging difficult



Mutual Authentication

Central to the problem of authenticated key exchange are two issues:

Confidentiality

Essential identification and session-key information must be communicated in **encrypted form**.

This requires the prior existence of **secret or public keys** that can be used for this purpose.

Timeliness

Important because of the threat of message replays!

Such replays could allow an opponent to:

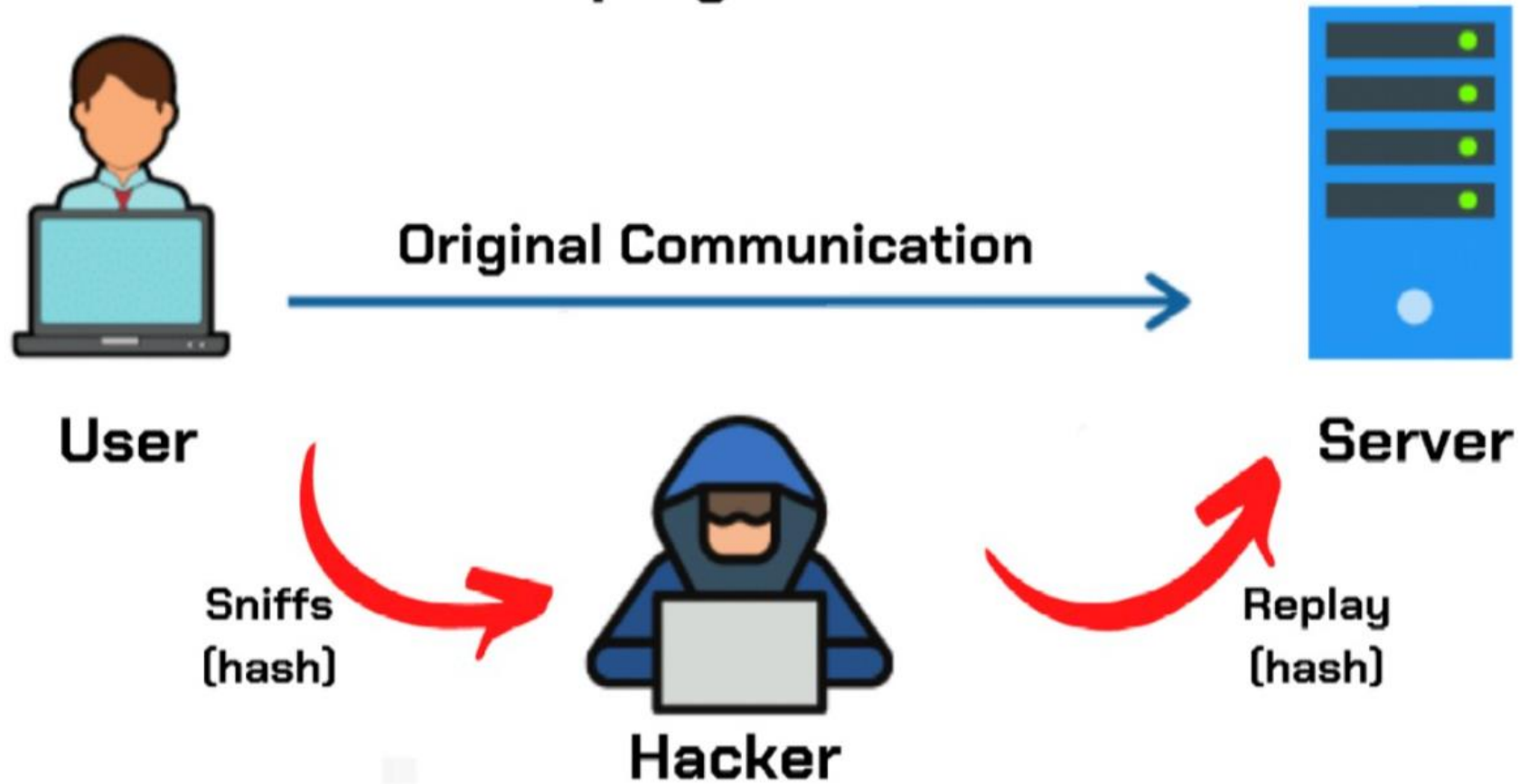
- compromise a session key**

- successfully impersonate another party**

- disrupt operations by presenting parties with messages that appear genuine but are not!**

What can go
wrong?

Replay attack



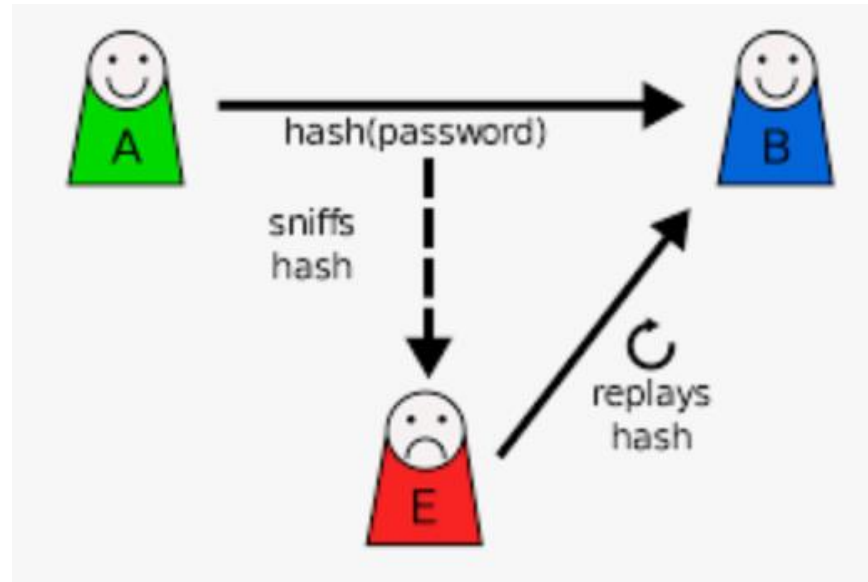
Replay attack

The simplest replay attack is one in which the opponent simply **copies a message** and **replays it later**.

An opponent can replay a **timestamped** message within the valid **time window**.

An opponent can replay a timestamped message within the valid time window, but in addition, the opponent suppresses the original message; thus, the **repetition cannot be detected**.

Another attack involves a **backward replay** without modification and is possible if symmetric encryption is used and the sender cannot easily recognize the difference between messages sent and messages received on the basis of content.



Approaches to Coping With Replay Attacks (1 of 2)

- Attach a sequence number to each message used in an authentication exchange
 - A new message is accepted only if its sequence number is in the proper order
 - Difficulty with this approach is that it requires each party to keep track of the last sequence number for each claimant it has dealt with
 - Generally not used for authentication and key exchange because of overhead

Approaches to Coping With Replay Attacks (2 of 2)

- Timestamps
 - Requires that clocks among the various participants be synchronized
 - Party A accepts a message as fresh only if the message contains a timestamp that, in A's judgment, is close enough to A's knowledge of current time
- Challenge/response
 - Party A, expecting a fresh message from B, first sends B a *nonce* (challenge) and requires that the subsequent message (response) received from B contain the correct nonce value



bristol.ac.uk

Impersonation attack

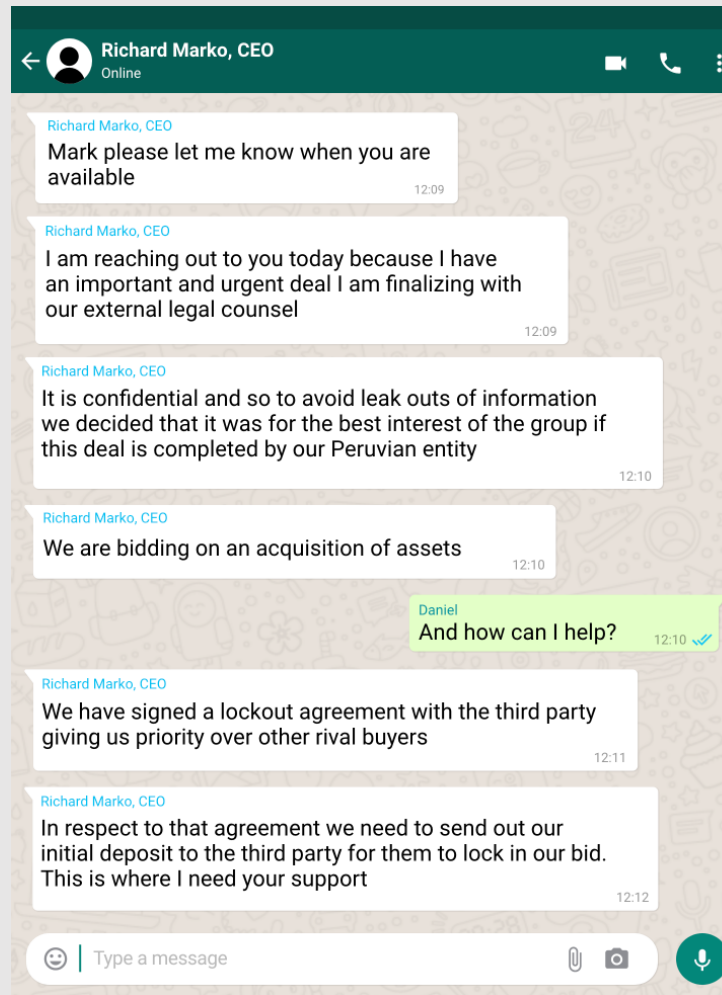
Cybercriminals usually **replay authentication sessions**, which give attackers full control of your accounts and all the privileges you enjoy on specific websites or apps.

They can **impersonate you** online, **send and receive messages on your behalf**, and **access confidential data** or documents.



A real story: Impersonation attack against ESET

Cyberattacks can happen to any organization.
In 2020, ESET faced CEO impersonation attempts via WhatsApp messages. The goal of this attempt was to fake the existence of a big bid that required a financial deposit.
Check out samples of these messages below.



AI impersonation

- 2019 - Deepfake Voice “CEO” Scam - criminals used AI-generated voice deepfakes to impersonate a company executive’s voice over the phone. In England, the CEO of an energy firm received a call that he believed was from his German parent company’s chief – he recognized the slight accent and tone. The deepfake “boss” urgently instructed him to wire \$243,000 to a Hungarian account, which he did.
- 2024 - Finance worker pays out \$25 million after video call with deepfake ‘chief financial officer’



ac.uk

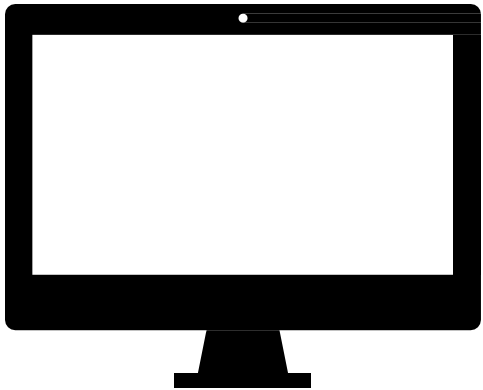


Authorization:

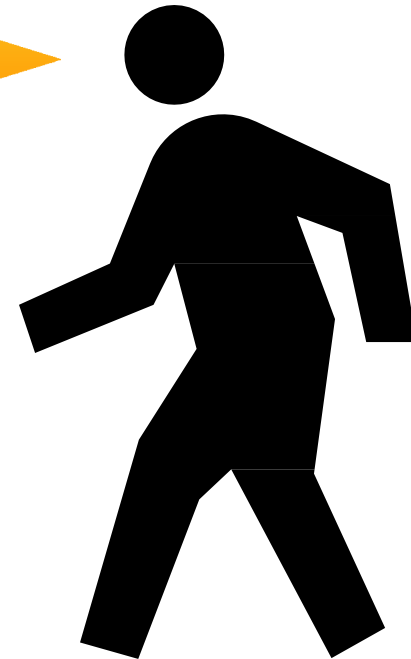
Or what can you do?

Authorization

What can you do?

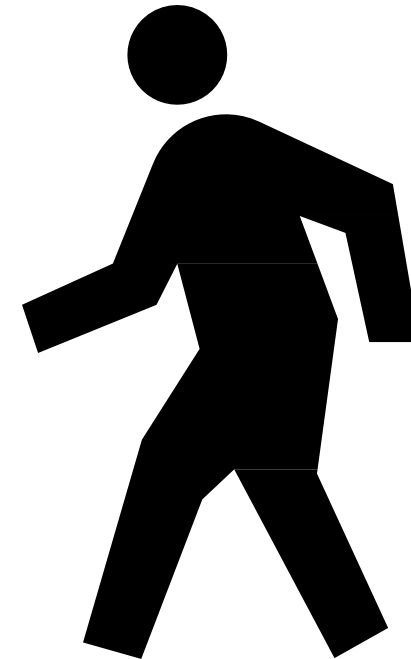


I am John Smith and I'd like
to edit Alice's files...



Authorization

What can you do?



Authorization

Distributed Access Control

Sometimes it'd be really nice to get information dynamically from third-parties instead of keeping it locally.

- *All MSc students can access MSc Room*
- *MSc manager can say who's a MSc Student*
- *Awaits can say who's the MSc manager*

Bob wants to access the MSc room...

?- bob canEnter.

X canEnter if X isMScStudent.

Y can-say X isMScStudent if Y isMScManager.

awais can-say Y isMScManager.

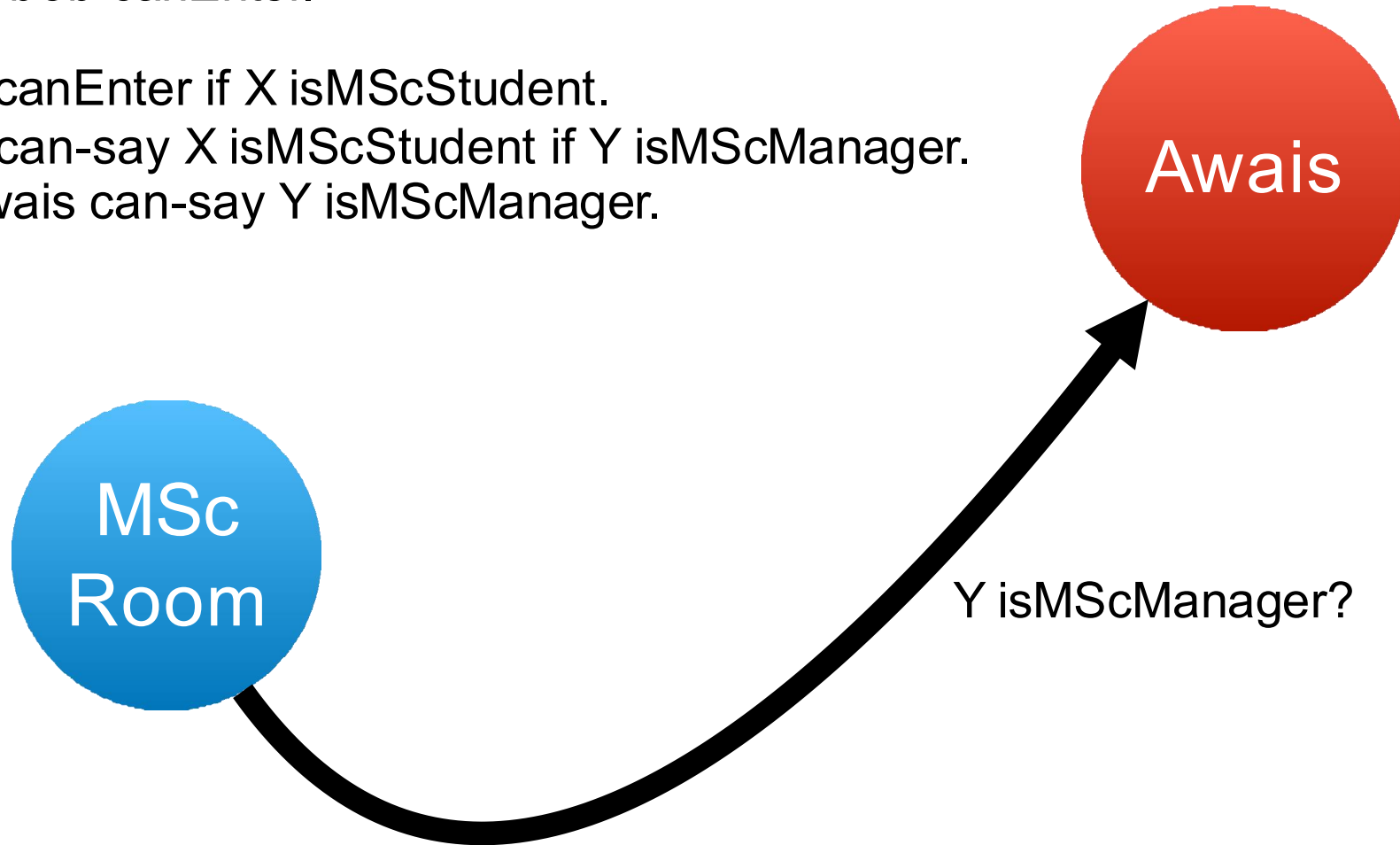


?- bob canEnter.

X canEnter if X isMScStudent.

Y can-say X isMScStudent if Y isMScManager.

awais can-say Y isMScManager.



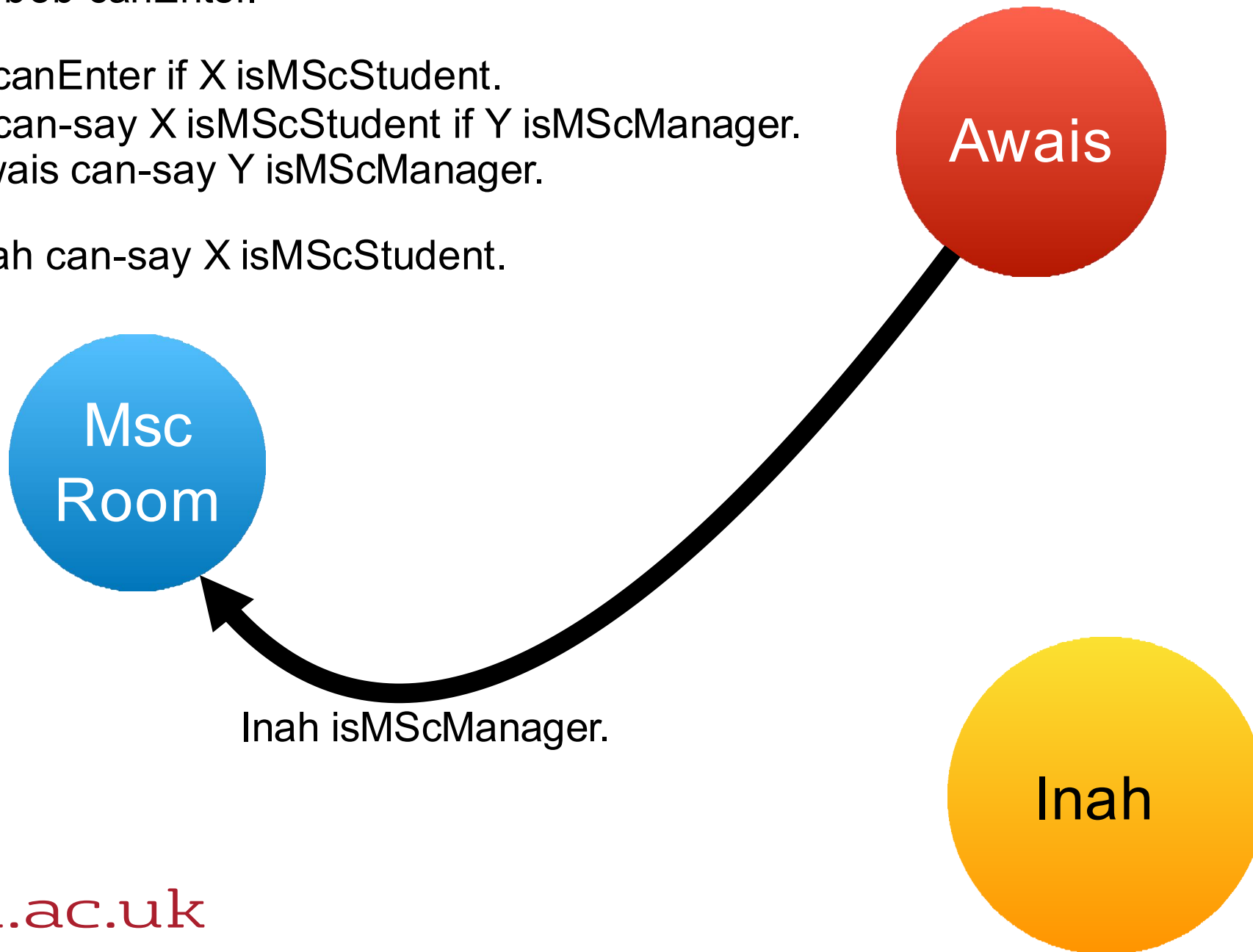
?- bob canEnter.

X canEnter if X isMScStudent.

Y can-say X isMScStudent if Y isMScManager.

awais can-say Y isMScManager.

Inah can-say X isMScStudent.



?- bob canEnter.

X canEnter if X isMScStudent.

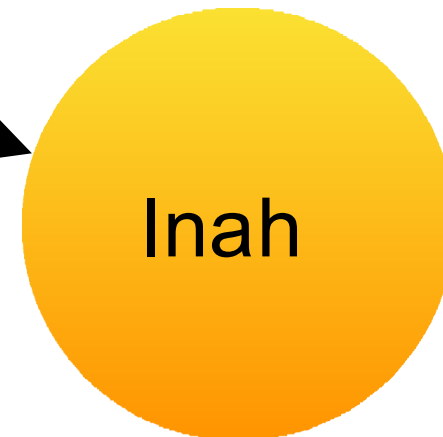
Y can-say X isMScStudent if Y isMScManager.

awais can-say Y isMScManager.

Inah can-say X isMScStudent.



bob isMScStudent?



?- bob canEnter.

X canEnter if X isMScStudent.

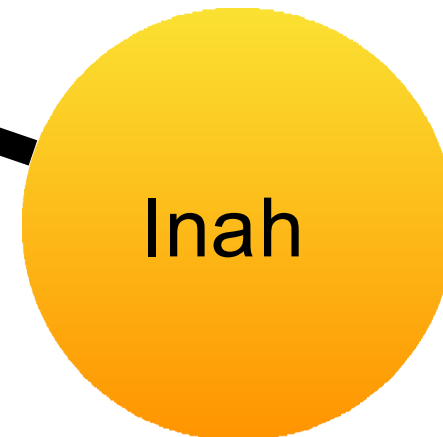
Y can-say X isMScStudent if Y isMScManager.

awais can-say Y isMScManager.

Inah can-say X isMScStudent.



bob isMScStudent.



?- bob canEnter.

X canEnter if X isMScStudent.

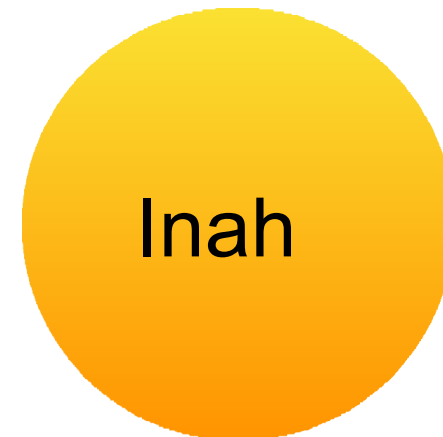
Y can-say X isMScStudent if Y isMScManager.

awais can-say Y isMScManager.

Inah can-say X isMScStudent. bob
isMScStudent.



<opens the door>



?- bob canEnter.

X canEnter if X isMScStudent.

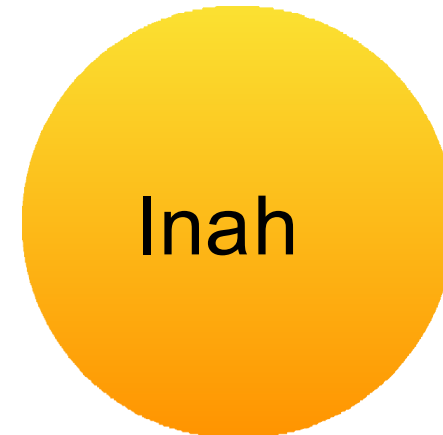
Y can-say X isMScStudent if Y isMScManager.

awais can-say Y isMScManager.

bob canEnter.



<opens the door>



Authorization

Role-Based Access Control

In the previous example Awais and Inah had jobs

- Awais could say who was a MSc manager...
- Inah could fulfill the role of a MSc manager...

RBAC lets us write policies with *roles*.

- Roles get assigned and removed at runtime
- More control than UNIX/POSIX DAC
- SELinux / SEAndroid

Authorization

SEAndroid

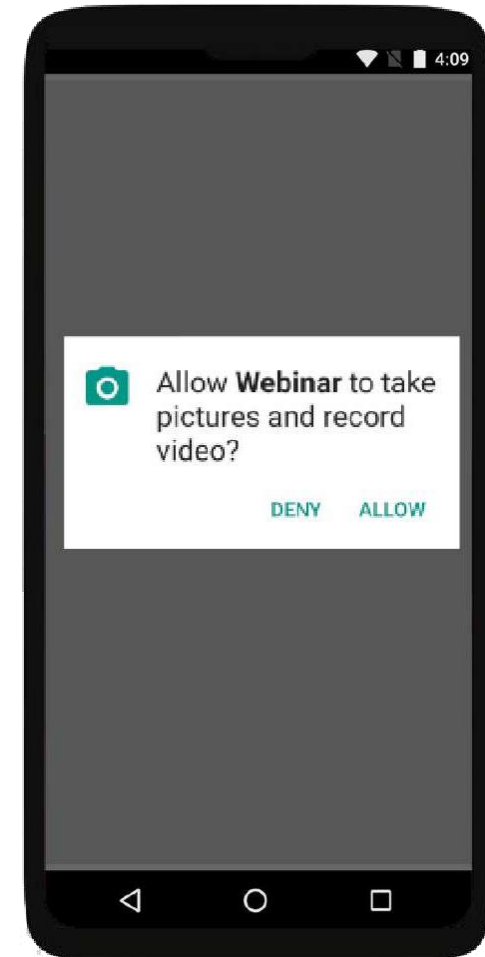
Mobile OSs have permissions to access various system features...

Android implements its permission system atop a Linux RBAC system called SELinux (called SEAndroid)

Source code is online!

<https://cs.android.com/android>

bristol.ac.uk



Authorization

Other schemes

What about if instead of just having role we have them assigned dynamically based on the time of day?

- Gary the Gatekeeper can open the front gate between 9am–5pm
- Nigel the Nightwatchman can open the gate from 5pm–9am

Attribute-based access control (ABAC)

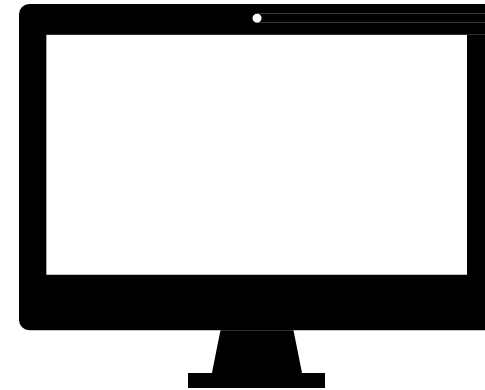
- Doesn't have to be time could be anything!

Accountability:

Or who did what?

Accountability

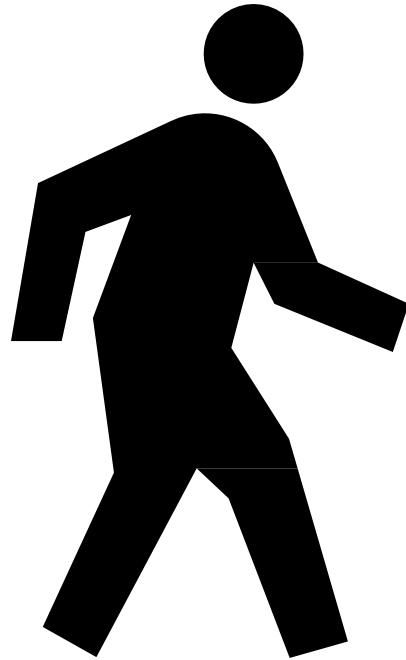
Who did what



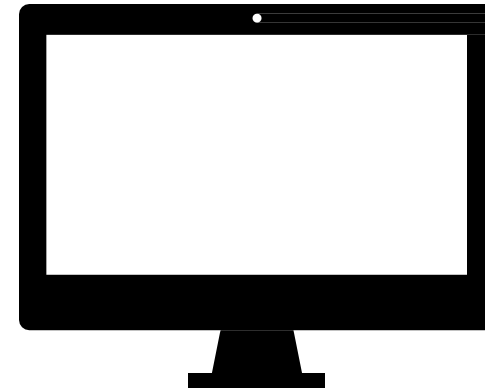
bristol.ac.uk

Accountability

Who did what



It was John Smith.



Logs



Accountability

Logging

Log as much as you can

- But don't be evil

Keep the logs *append* only

- And get them off the machine ASAP
- Hackers like to delete/modify logs

Standard-ish log formats

```
127.0.0.1 [01/Dec/2020:13:55:36 -0000] "GET /slides HTTP/1.0" 200 4007
```

Accountability

Proof Carrying Code / Digital Evidence

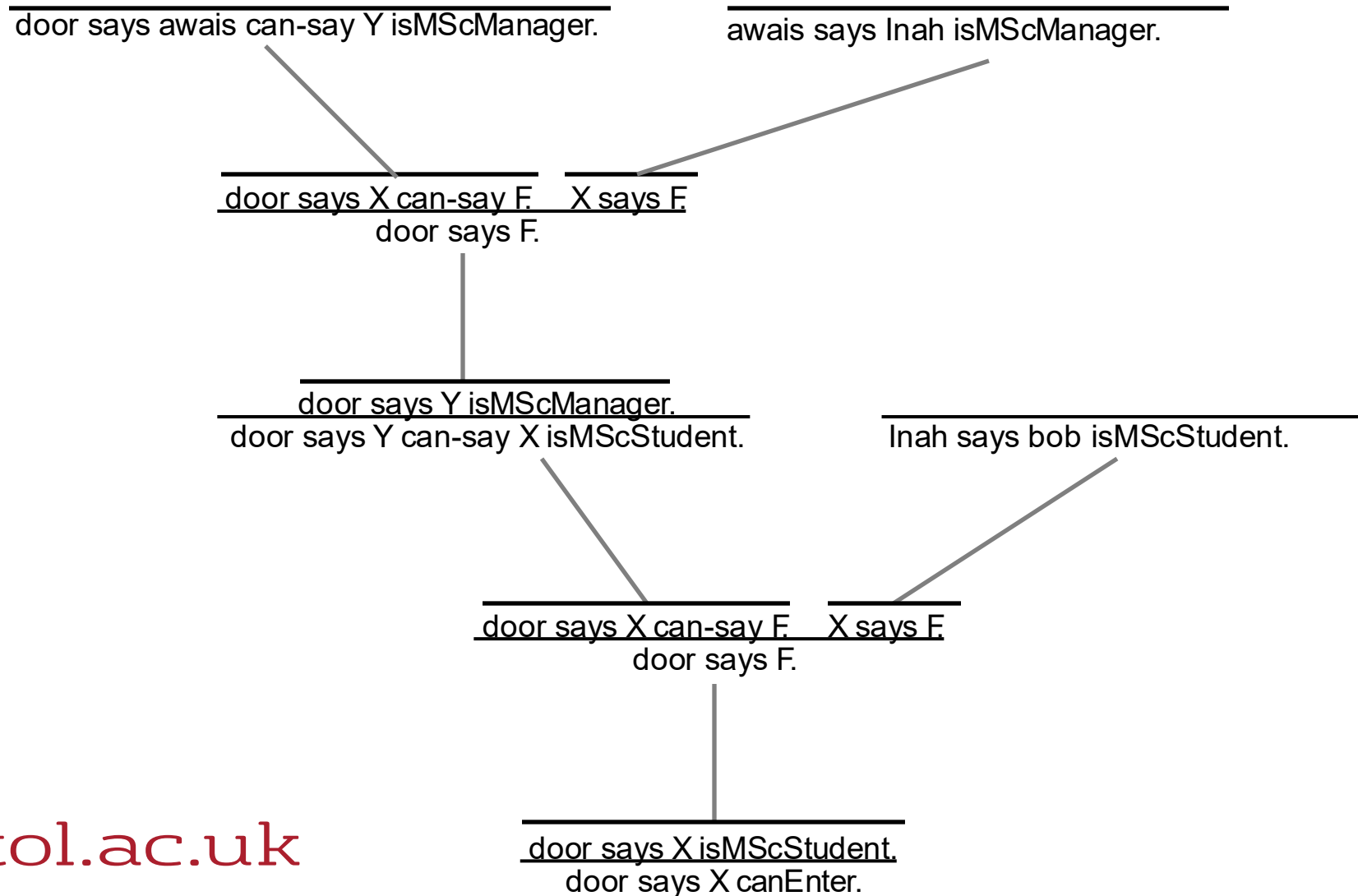
Suppose I have some authorisation logic making decisions about who I let in...

Deriving a proof that someone is allowed in can take a lot of time...

But checking a proof can usually be done quickly!

Check unconnected facts are known

Check transitions can be derived with one of the rules



AAA Further Reading

- CyBOK's discussion of AAA is pretty good.
- SELinux Coloring Book
- NCSC Introduction to identity and access management
 - <https://www.ncsc.gov.uk/guidance/introduction-identity-and-access-management>
- Butler Lampson, Martín Abadi, Michael Burrows, and Edward Wobber. 1992. Authentication in distributed systems: theory and practice. *ACM Trans. Comput. Syst.* 10, 4 (Nov. 1992).

